

Manual 23 — DORA Controlled Implementation

Controlled English master — development

****Series order:**** 23

****Primary statutory baseline:**** Regulation (EU) 2022/2554 (DORA)

****Source-layer rule:**** statutory text, delegated/implementing acts, supervisory materials, contractual practice, and internal procedures remain distinct.

****Boundary:**** This manual does not replace GDPR, NIS2, sectoral prudential requirements, national law, or competent-authority instructions.

01. Governance and accountability

Establish a management-body-approved digital operational resilience framework with named accountability, decision rights, reporting cadence, escalation thresholds, and evidence retention. Record accountable owners, delegated responsibilities, material decisions, challenge, and remediation follow-up.

02. Scope and applicability

Determine which legal entities, services, branches, ICT assets, and outsourcing arrangements fall within DORA. Keep scope conclusions tied to legal-entity and service facts; do not generalize financial-entity applicability beyond supported evidence.

03. ICT risk-management framework

Maintain a documented ICT risk-management framework integrated with enterprise risk management. Define objectives, control domains, risk appetite/tolerance, exception handling, testing, and reassessment triggers.

04. Asset and dependency mapping

Maintain current inventories of information assets, ICT assets, systems, applications, data flows, critical functions, dependencies, interfaces, and third-party services. Map business-service dependencies to technical components and accountable owners.

05. Protection and prevention

Implement preventive safeguards proportionate to risk, including access control, secure configuration, change control, network protection, encryption, malware defenses, vulnerability management, secure development, and physical/environmental protections where applicable.

06. Detection

Define monitoring and detection capabilities for anomalous activity, service degradation, integrity failures, unauthorized access, control failure, and third-party disruption. Preserve alert logic, ownership, triage criteria, and evidence.

07. Response

Maintain documented ICT incident response procedures covering classification, command, communication, containment, investigation, recovery coordination, evidence preservation, decision logging, and regulatory-notification routing.

08. Recovery and restoration

Define recovery priorities, recovery objectives, restoration procedures, alternate processing, dependency sequencing, integrity checks, and business validation before services return to normal operation.

09. Backup and restoration controls

Use resilient backup arrangements with defined scope, frequency, retention, segregation, immutability or equivalent protection where appropriate, restoration testing, and evidence that recovery objectives remain achievable.

10. Learning and improvement

Conduct structured post-incident and post-test reviews. Record root causes, control gaps, lessons learned, corrective actions, owners, due dates, verification evidence, and reassessment triggers.

11. Communication

Maintain internal and external communication procedures for major ICT disruptions. Define stakeholders, message approval, escalation, media/market/customer considerations, and regulatory-contact responsibilities.

12. ICT incident classification

Use documented criteria for classifying ICT-related incidents. Keep internal severity models distinct from regulatory classification criteria and reverify applicable thresholds and technical standards before release and use.

13. Major-incident reporting

Maintain a fail-closed process for determining whether an ICT-related incident meets major-incident reporting requirements. Track competent authority, required fields, submission stages, deadlines, evidence, and corrections. Reverify current templates and timing rules before operational use.

14. Voluntary cyber-threat notification

Keep voluntary notification of significant cyber threats separate from mandatory major-incident reporting. Document decision authority, rationale, recipients, and any resulting obligations.

15. Testing strategy

Maintain a risk-based digital operational resilience testing programme covering systems and ICT services supporting critical or important functions. Define test scope, frequency, independence, evidence, remediation, and retest requirements.

16. Vulnerability assessments

Perform vulnerability assessments using methods proportionate to system criticality and exposure. Track findings, severity, compensating controls, remediation deadlines, exceptions, evidence, and closure verification.

17. Scenario and resilience testing

Use scenario-based testing to validate resilience under plausible severe disruption. Include people, process, technology, facilities, communications, third-party dependencies, and recovery decision-making.

18. Threat-led penetration testing

Where applicable, manage threat-led penetration testing as a distinct control regime. Verify entity applicability, scope, tester requirements, authority expectations, evidence, remediation, and retest obligations before execution.

19. Tester independence and competence

Define independence, competence, conflict-of-interest, confidentiality, authorization, and evidence requirements for internal and external testers. Keep formal regulatory requirements distinct from internal quality expectations.

20. Remediation and retesting

Track test and assessment findings through a controlled remediation lifecycle with owner, risk rating, target date, exception authority, closure evidence, and retest where required.

21. ICT third-party risk framework

Maintain governance for ICT third-party risk across onboarding, due diligence, contracting, monitoring, incident handling, concentration analysis, change, renewal, exit, and evidence retention.

22. Pre-contract due diligence

Before entering ICT arrangements, assess provider capability, security, resilience, data handling, legal/regulatory fit, subcontracting, geographic dependencies, auditability, continuity, exit feasibility, and concentration effects.

23. Contractual controls

Use contractual provisions appropriate to service criticality and applicable DORA requirements. Address service description, locations, security, incident support, access/audit rights, continuity, data return, termination, cooperation, and regulatory access as applicable.

24. Subcontracting and chain risk

Identify material subcontracting chains, critical dependencies, locations, substitution risk, concentration, change notification, and downstream control obligations. Do not treat prime-provider oversight as eliminating chain risk.

25. Concentration risk

Assess concentration across providers, services, technologies, geographic regions, data locations, common infrastructure, and substitutability. Document assumptions, stress scenarios, mitigations, and management decisions.

26. Register of information

Maintain the register of information required for relevant ICT third-party arrangements using current prescribed structure and data fields. Reverify templates, taxonomy, submission expectations, and competent-authority instructions before filing.

27. Critical ICT third-party providers

Maintain controls for dependencies on providers designated or potentially subject to the EU oversight framework for critical ICT third-party providers. Distinguish provider oversight from each financial entity's own continuing responsibilities.

28. Exit and transition planning

Create tested exit and transition plans for ICT services supporting critical or important functions. Address data portability, alternate providers, insourcing feasibility, sequencing, continuity, knowledge transfer, contractual triggers, and residual risk.

29. Operational resilience metrics

Define metrics and indicators for incidents, recovery, testing, third-party performance, vulnerabilities, remediation, exceptions, concentration, and control effectiveness. Tie metrics to decisions and escalation rather than reporting volume alone.

30. Evidence and supervisory readiness

Maintain evidence objects for each material control, including policy, owner, procedure, operating record, test result, exception, remediation, approval where required, and reassessment. Ensure records can support internal audit, external assurance, and competent-authority requests.

31. Localization and implementation control

Translate only from an exact frozen English source. Preserve legal and regulatory terms, incident-reporting distinctions, third-party terminology, scope boundaries, and unofficial-translation status. Run structural and semantic parity checks before candidate generation.

32. Source watch, change control, provenance, and release

Before candidate freeze and publication, reverify Regulation (EU) 2022/2554 applicability, delegated and implementing acts, ESA materials, incident-reporting technical standards, TLPT requirements, register-of-information specifications, and relevant supervisory updates. Bind the exact source commit, localized sources, DOCX/PDF binaries, SHA-256 identities, rendered/accessibility QA, workflow-security results, predecessor publication state, and release-registry reconciliation. If no unresolved material defect remains and all applicable objective gates are green, publish under the repository standing authorization rule.

Control-record minimum for every chapter

For each substantive chapter, implementation records should identify: applicable source layer; applicability decision; accountable owner; operating procedure; evidence object/location; review or test method; exception/remediation path; and reassessment trigger.